RHAPSODY

CUSTOMER SECURITY ADVISORY

eMudhra CA compromise

Rhapsody Engine customer security advisory

PREPARED BY	DATE	AUDIENCE	VERSION
Rhapsody Security and Engineering	November 6, 2026	Customer use	1.0

eMudhra CA compromise

CONTENTS

01 Summary
02 Background
03 Potential impacts
04 Affected connections
05 Not affected
06 Affected root CAs
07 Solution
08 Delete commands by version
09 FAQ
10 References

Important: This article will be modified as Rhapsody investigates this further. This article is current as of 6 November, 2026.

SECTION 01

Summary

The Java runtime bundled with the Rhapsody engine trusts eMudhra intermediate CA certificates that were issued with weak private keys (issued from April 2025, disclosed October 2026). The Java exposure is tracked as CVE-2026-91403, and the OpenJDK guidance on removing the affected root CAs as CVE-2026-114820. Forged server certificates signed with these intermediates would be accepted on outbound TLS connections.

This article explains how the issue affects your Rhapsody engine and what to do about it. It lists the Rhapsody versions and communication points that are affected. Following the OpenJDK guidance for CVE-2026-114820, you then remove the affected root certificate authorities (CAs) from the JRE bundled with your engine and restart the engine.

Affected Rhapsody versions: All Rhapsody versions up to and including Rhapsody 7.8.x are impacted. This includes Rhapsody 6.x, 5.x, 4.x etc. All Rhapsody releases available as of October 2026 bundle a Temurin JRE below the patched version (6.x releases bundle JDK 8). Rhapsody 7.9 (estimated release January 2027) will bundle a Temurin JRE that addresses this issue. Until then, apply the steps below.

SECTION 02

Background

eMudhra issued 8 intermediate CA certificates with weak private keys that can be derived from the public certificates. Each intermediate chains to two roots: emSign ECC Root CA - G3 (through emSign Root TLS CA - G3) and Sectigo's AAA Certificate Services (through a cross-signature). Java does not check revocation by default, so eMudhra's revocation and the browser blocks do not protect the Rhapsody JVM.

Rhapsody engines that pre-date the compromised certificates are still affected, even though the certificates were only issued in April 2025. Java decides what to trust by checking a certificate against a built-in list of trusted organisations (root certificates). It does this each time a connection is made, not when that version of Java was released. Some of the compromised certificates link back to a long-standing root (Sectigo's "AAA Certificate Services") that older Java versions still trust. As a result, an old Java (from an old Rhapsody engine) will accept a fake certificate built with the leaked keys, even though it predates the certificates themselves.

SECTION 03

Potential impacts

The risk is a man-in-the-middle attack. An attacker who can get onto the network path to a server Rhapsody connects to can present a forged certificate, pose as that server, and receive credentials or PHI sent by the engine.

Rhapsody rates the likelihood of exploitation as **low**. For an attack to succeed against your engine, all the following must be true at the same time:

- The connection trusts the affected public roots. That means a communication point that uses the JRE's default trust store (`cacerts`). Communication points that trust only specific certificates configured in the Certificate Manager, or a private CA, are not exposed.
- The attacker is on the network path between the engine and the remote server, through compromised DNS, a compromised network segment, or a hostile proxy. Most Rhapsody deployments run inside hospital networks or private cloud environments with private connectivity to downstream systems, which makes this considerably less likely.
- The attacker has forged a certificate for that specific server using one of the recovered keys. This is technically simple but must be done per target.

Regardless of the likelihood, Rhapsody recommends applying the fix on every engine.

SECTION 04

Affected connections

Connections where Rhapsody is the TLS client and validates the server certificate against public CAs. For example, outbound HTTPS, REST and SOAP connections, and connections to cloud services such as Amazon and Azure.

The following communication points use the JRE's default trust store (`cacerts`) and are affected:

Communication point	When it's affected
HTTP Client	Only when no trusted certificates are configured in the Certificate Manager
SOAP Web Service Client (formerly Web Service Client)	Only when no trusted certificates are configured in the Certificate Manager
JavaScript REST Client (v.1)	Only when no trusted certificates are configured in the Certificate Manager
JavaScript REST Client (v.2)	Only when no trusted certificates are configured in the Certificate Manager
Microsoft Exchange	Always. It doesn't use the Certificate Manager.
Amazon S3	Always. It doesn't use the Certificate Manager.
Amazon SNS	Always. It doesn't use the Certificate Manager.
Amazon SQS	Always. It doesn't use the Certificate Manager.
Azure Service Bus	Always. It doesn't use the Certificate Manager.
E-mail Client (OAuth2 token fetch only)	In output mode with OAuth2 enabled. The mail connection itself is not affected.
Database (indirect)	When the JDBC connection uses TLS. This depends on the database driver and connection string, not Rhapsody.

SECTION 05

Not affected

- Plaintext connections, such as HL7 v2 over MLLP without TLS.
- HTTP Client, SOAP Web Service Client and JavaScript REST Client when trusted certificates are configured in the Rhapsody Certificate Manager. They validate against those certificates only and never use `cacerts`.
- Inbound TLS where Rhapsody is the server (TCP Server, HTTP Server and SOAP Web Service Hosting). Systems calling Rhapsody need their own fix.

The following communication points do not use the JRE's default trust store and are not affected:

Communication point	Why it's not affected
TCP Client	Uses the Certificate Manager, or trusts all certificates (Anonymous mode)
TCP Server	Uses the Certificate Manager (server mode)
JavaScript TCP Client	Same behaviour as TCP Client
JavaScript TCP Server	Same behaviour as TCP Server
(S)FTP Client	Uses the Certificate Manager
E-mail Client (mail connection)	Uses the Certificate Manager, or trusts all certificates (Anonymous mode)
JMS	Uses the Certificate Manager, or an empty trust manager
AMQP	Uses the Certificate Manager, or trusts all certificates (Anonymous mode)
Kafka	Uses the truststore file you specify
Rhapsody Connector	Uses the Certificate Manager, or trusts all certificates (Anonymous mode)
HTTP Server	Uses the Certificate Manager (server mode)
SOAP Web Service Hosting	Uses the Certificate Manager (server mode)
Clinicom Client	Same behaviour as TCP Client
Clinicom Server	Same behaviour as TCP Server
ASTM TCP Client	Same behaviour as TCP Client
ASTM TCP Server	Same behaviour as TCP Server

The following communication points do not use TLS:

Directory	Dynamic Router	Sink	Timer
Printer	Error Message Redirector	Execute Command	Watchlist Notifier
Semantic CrossMap Direct Lookup	Database Insertion	HylaFAX Client	MSMQ Client
SNA	TN3270	SMS Batch	SMS Invision

SECTION 06

Affected root CAs

The solution removes these root CAs from the JRE's `cacerts` file:

- emSign ECC Root CA - G3: the compromised intermediates chain to this root.
- AAA Certificate Services: the Sectigo/Comodo root that cross-signed the compromised intermediates. Not present in some newer Temurin builds; ignore if not found.
- emSign Root CA - C1: eMudhra Inc (US entity, being retired). No production certificates were issued under this root, so removal carries no disruption risk.
- emSign ECC Root CA - C3: same eMudhra US hierarchy, same status as C1. Ignore if not found.

SECTION 07

Solution

This solution involves removing the affected root CAs from the `cacerts` file of the JRE bundled with your engine, then restarting the engine.

Apply these steps in a non-production environment before you apply them in production.

> **Caution:** Removing the AAA Certificate Services root may affect outbound TLS communication points that use the JRE trust store (see Affected connections). If a legitimate server stops connecting afterwards, see the FAQ.

Repeat these steps for each Rhapsody engine.

> **Note:** The `keytool` command is in the JRE's `bin` folder (`<JRE path>/bin`). Run all `keytool` commands in these steps from that folder, using `./keytool` on Linux and `.\keytool.exe` in PowerShell on Windows (run PowerShell as Administrator).

1. **Back up cacerts.** The `cacerts` file is in the following locations, where `<JRE path>` is the engine's JRE folder:
   - Linux: `<JRE path>/lib/security/cacerts` , for example `/opt/Rhapsody/jre/lib/security/cacerts`
   - Windows: `<JRE path>\lib\security\cacerts` , for example `C:\Program Files\Rhapsody\Rhapsody Engine 78\jre\lib\security\cacerts`

   On Rhapsody 6.x (Java 8), the file is at `<JRE path>/jre/lib/security/cacerts` . Use `<JRE path>/jre` wherever the commands say `<JRE path>` .

   The file can be backed up manually. To back it up by script, use the following commands:
   - Linux: `cp <JRE path>/lib/security/cacerts <JRE path>/lib/security/cacerts.bak`
   - Windows (PowerShell, as Administrator): `Copy-Item "<JRE path>\lib\security\cacerts" "<JRE path>\lib\security\cacerts.bak"`

2. **Check the keystore.** List the affected entries before you change anything.
   - Linux:

     ```
     ./keytool -list -keystore "<JRE path>/lib/security/cacerts" -storepass changeit 2>/dev/null | grep -i -e
     "emsign" -e "comodoaaa" -e "aaa.certificate"
     ```

   - Windows (PowerShell):

     ```
     .\keytool.exe -list -keystore "<JRE path>/lib/security/cacerts" -storepass changeit 2>$null | Select-String
     -Pattern "emsign|comodoaaa|aaa.certificate"
     ```

   The text before the date on each line is the alias. Expect to see some or all of the roots listed in Affected root CAs (G3, AAA, C1 and C3). Not every root is present in every version, so a missing root is fine. If emSign Root CA - G1 is listed, leave it in place.

   Example (Rhapsody 7.8.4 on Windows). In PowerShell, as Administrator, go to the JRE's `bin` folder with `cd "C:\Program Files\Rhapsody\Rhapsody Engine 78\jre\bin"`, then run:

   ```
   .\keytool.exe -list -keystore "C:/Program Files/Rhapsody/Rhapsody Engine 78/jre/lib/security/cacerts" -storepass
   changeit 2>$null | Select-String -Pattern "emsign|comodoaaa|aaa.certificate"
   ```

   The result shows the three affected roots to remove, G3, C1 and C3, along with G1:

   ```
   cn=emsign_ecc_root_ca_-_c3,o=emudhra_inc,ou=emsign_pki,c=us, 22/07/2026, trustedCertEntry,
   cn=emsign_ecc_root_ca_-_g3,o=emudhra_technologies_limited,ou=emsign_pki,c=in, 22/07/2026, trustedCertEntry,
   cn=emsign_root_ca_-_c1,o=emudhra_inc,ou=emsign_pki,c=us, 22/07/2026, trustedCertEntry,
   cn=emsign_root_ca_-_g1,o=emudhra_technologies_limited,ou=emsign_pki,c=in, 22/07/2026, trustedCertEntry,
   ```

   G1 is not on the removal list, so leave it in place. AAA Certificate Services is not listed because this version does not include it.

3. **Delete the affected roots.** Find your Rhapsody version in Delete commands by version, and replace `<JRE path>` with the path from step 1. Ignore errors saying an alias does not exist; not all roots are present in all JRE versions. If your version is earlier than 6.5, follow the instructions under Versions not listed.

   Example (Rhapsody 7.8.4 on Windows). Run the commands one at a time or together:

   ```
   .\keytool.exe -delete -keystore "C:/Program Files/Rhapsody/Rhapsody Engine 78/jre/lib/security/cacerts" -
   storepass changeit -alias "cn=emsign_ecc_root_ca_-_g3,o=emudhra_technologies_limited,ou=emsign_pki,c=in"

   .\keytool.exe -delete -keystore "C:/Program Files/Rhapsody/Rhapsody Engine 78/jre/lib/security/cacerts" -
   storepass changeit -alias "cn=emsign_ecc_root_ca_-_c3,o=emudhra_inc,ou=emsign_pki,c=us"

   .\keytool.exe -delete -keystore "C:/Program Files/Rhapsody/Rhapsody Engine 78/jre/lib/security/cacerts" -
   storepass changeit -alias "cn=emsign_root_ca_-_c1,o=emudhra_inc,ou=emsign_pki,c=us"
   ```

4. **Verify the keystore.** Run the listing from step 2 again. None of the roots listed in Affected root CAs (G3, AAA, C1 and C3) should be listed. emSign Root CA - G1 may still be listed, because it is not on the removal list. If any of the four remain, repeat step 3 for that entry, using its exact alias from the listing.

   Example (Rhapsody 7.8.4 on Windows). After the deletes in step 3, the same listing returns only G1:

   ```
   cn=emsign_root_ca_-_g1,o=emudhra_technologies_limited,ou=emsign_pki,c=in, 22/07/2026, trustedCertEntry,
   ```

   The G3, C1 and C3 entries are gone.

5. **Restart the Rhapsody engine.** The JVM reads `cacerts` only at startup. The engine is not protected until it has been restarted.

SECTION 08

Delete commands by version

Run the commands for your Rhapsody version on the engine's host. Replace `<JRE path>` with the path to the engine's JRE (see Solution, step 1). Each set applies to all patch releases within the stated range.

Run the commands from `<JRE path>/bin` (see Solution). They are shown as `keytool`; in that folder, use `./keytool` on Linux and `.\keytool.exe` in PowerShell on Windows. The commands use forward slashes, which `keytool` accepts on both Linux and Windows. Keep the double quotes around the `-keystore` value, as the JRE path may contain spaces.

8.1 Rhapsody 6.5 to 6.6

Only the AAA Certificate Services root is present in these versions, so there is a single command.

```
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "comodoaaaca [jdk]"
```

8.2 Rhapsody 6.7 to 7.0 (including 6.10)

```
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "subject=c = gb, st = greater
manchester, l = salford, o = comodo ca limited, cn = aaa certificate services"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "subject=c = in, ou = emsign
pki, o = emudhra technologies limited, cn = emsign ecc root ca - g3"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "subject=c = us, ou = emsign
pki, o = emudhra inc, cn = emsign ecc root ca - c3"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "subject=c = us, ou = emsign
pki, o = emudhra inc, cn = emsign root ca - c1"
```

8.3 Rhapsody 7.1 to 7.3

```
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "c = gb, st = greater
manchester, l = salford, o = comodo ca limited, cn = aaa certificate services"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "c = in, ou = emsign pki, o =
emudhra technologies limited, cn = emsign ecc root ca - g3"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "c = us, ou = emsign pki, o =
emudhra inc, cn = emsign ecc root ca - c3"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "c = us, ou = emsign pki, o =
emudhra inc, cn = emsign root ca - c1"
```

8.4 Rhapsody 7.4 to 7.7

```
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias
"cn=aaa_certificate_services,o=comodo_ca_limited,l=salford,st=greater_manchester,c=gb"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "cn=emsign_ecc_root_ca_-
_g3,o=emudhra_technologies_limited,ou=emsign_pki,c=in"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "cn=emsign_ecc_root_ca_-
_c3,o=emudhra_inc,ou=emsign_pki,c=us"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "cn=emsign_root_ca_-
_c1,o=emudhra_inc,ou=emsign_pki,c=us"
```

8.5 Rhapsody 7.8.0 to 7.8.6

AAA Certificate Services is not present in this version, so there is no command for it.

```
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "cn=emsign_ecc_root_ca_-
_g3,o=emudhra_technologies_limited,ou=emsign_pki,c=in"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "cn=emsign_ecc_root_ca_-
_c3,o=emudhra_inc,ou=emsign_pki,c=us"
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "cn=emsign_root_ca_-
_c1,o=emudhra_inc,ou=emsign_pki,c=us"
```

8.6 Versions not listed

For versions earlier than 6.5, use the listing in Solution, step 2 to find the exact aliases, then delete each entry containing G3, C1, C3, or AAA. Aliases differ between JRE builds and Rhapsody versions, so do not copy aliases from other guides.

```
keytool -delete -keystore "<JRE path>/lib/security/cacerts" -storepass changeit -alias "<alias from the listing>"
```

SECTION 09

FAQ

9.1 Do I repeat the steps after an upgrade?

Yes, if you upgrade to any version before 7.9 (for example, from 7.3.0 to 7.8.4). An upgrade installs a new JRE, which replaces `cacerts`, so reapply the steps for the new version. Rhapsody 7.9 (estimated release January 2027) is expected to ship with a JRE that already removes the affected roots. After upgrading to 7.9, run the listing in Solution, step 2. If none of the roots (G3, AAA, C1 and C3) are listed, no further action is needed.

9.2 What if a server stops connecting?

If a legitimate server stops connecting after you remove the roots, its certificate chains to the 2004-era AAA Certificate Services root. Ask the system owner to provide a certificate from a current chain. If necessary, as a temporary stopgap, re-add just that root manually with `keytool -importcert`. This restores trust in the compromised cross-signed intermediates for that JRE, so remove the root again as soon as the server has a new certificate.

SECTION 10

References

- OpenJDK Vulnerability Advisory 2026-10-21: https://openjdk.org/groups/vulnerability/advisories/2026-10-21
- OpenJDK Vulnerability Advisory 2026-10-24 (CVE-2026-114820): https://openjdk.org/groups/vulnerability/advisories/2026-10-24
- OpenJDK guidance on root removal: https://openjdk.org/emudhra
- Oracle Security Alert (CVE-2026-114820): https://www.oracle.com/security-alerts/alert-cve-2026-114820.html
- Temurin fix (NSS 3.131.1 update): https://github.com/adoptium/temurin-build/pull/4587
- Mozilla bug 2083709 (C1/C3 removal from NSS root store): https://bugzilla.mozilla.org/show_bug.cgi?id=2083709
- Cloudflare - eMudhra certificate compromise: https://blog.cloudflare.com/emudhra-certificate-compromise/